
Cyberboswachters

De beste digitale stropers zijn ook de beste cyberboswachters

Dams Tim



De fundamenteën van cybersecurity

“Iedere goede film begint met een zwart scherm”, dixit Batman in de “The Lego Batman Movie”™ film. Wel, en iedere goed hoofdstuk begint met een definitie, dixit Tim Dams.

Laten we daarom eerst eens een definitie van cyber security neerpennen die het Cisco gebruikt:

"Cybersecurity is the practice of protecting systems, networks, and programs from digital attacks. These cyberattacks are usually aimed at accessing, changing, or destroying sensitive information; extorting money from users; or interrupting normal business processes."

Implementing effective cybersecurity measures is particularly challenging today because there are more devices than people, and attackers are becoming more innovative."

Alles draait met andere woorden rond het beschermen van informatie, dat die nu op een server, in een document of in iemand hoofd zit.

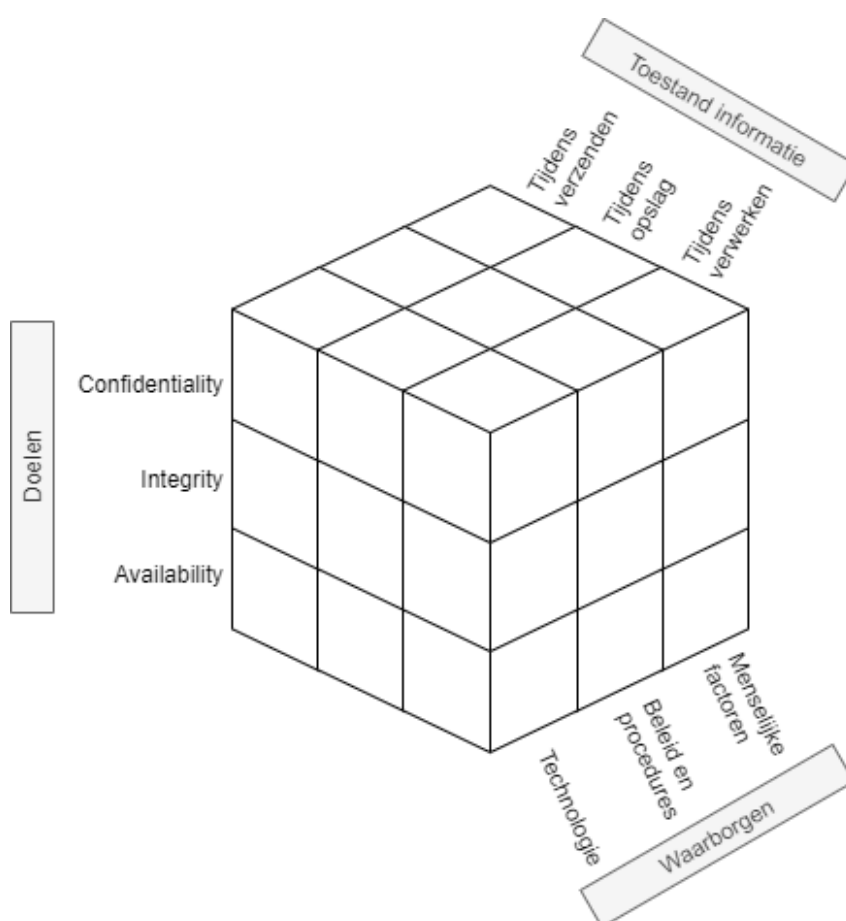
CIA en het security model

Data (of informatie), in welke vorm dan ook (berichten over een netwerk, bestanden op een harde schijf, tekst in een database), moet beschermd worden, dat beseffen we nu. Het doel van onze data is dat deze voldoet aan het acroniem **C.I.A** wat staat voor:

- **C** voor “**confidentiality**”: vertrouwelijkheid. De data kan enkel door zij die er recht toe hebben gebruikt worden. We gaan dit onder andere oplossen met behulp van encryptie en paswoorden.
- **I** voor “**integrity**”: integriteit. We moeten weten of onze data onbeschadigd is en niet werd aangepast door derden (of storingen). Bij bestanden gaan we bijvoorbeeld werken met zogenaamde (secure) hashes.
- **A** voor “**availability**”: beschikbaarheid. Data die niet door rechtmatige gebruikers kan bereikt worden is onbestaande data. Zogenaamde “denial-of-service” (dos) aanvallen hebben als doel deze pijler van CIA aan te vallen. availability is een breed veld en wordt onder andere opgelost door backups, redundante servers enerzijds, en preventieve maatregelen anderzijds zoals firewalls, load balancers, etc.

De zogenaamde McCumber kubus, ontwikkeld door John McCumber in 1991, geeft een goed beeld weer waarom het steeds belangrijk is goed te beseffen binnen welke context we praten. Deze kubus stelt een model voor dat kan gebruikt worden om je ervan te vergewissen dat je aan alles denkt wanneer je je informatie wilt beschermen. De kubus bestaat uit 3 dimensies en iedere dimensie bestaat uit een aantal aspecten. **Enkel wanneer we alle aspecten van alle dimensies in onze beveiligingsaanpak voorzien kunnen we hopen dat we onze C.I.A. doelen hebben bereikt.**

Om ons doel te bereiken (C.I.A.) moeten we ervoor zorgen dat we dit toepassen op alle vormen die onze data kan hebben (opslag, verzenden, verwerken). Dit kunnen we tewerkstellingen door technologische oplossingen (zoals encryptie wat in het volgende hoofdstuk wordt uitgespit), maar een niet onbelangrijke factor zijn ook de mensen die met de data moeten werken. Als zij zich niet aan de afspraken (procedures) houden en hun paswoorden gewoon op post-its aan hun scherm hangen, dan mag je een nog zo'n dure firewall hebben, het zal niet baten.



Figuur 0.1: De McCumber kubus

Waarom cyberboswachters het zo moeilijk hebben

De McCumber kubus is een mooi concept, maar het is ook niet meer dan dat: een theoretisch framework. Het is ideaal om vanuit een high-level perspectief je ervan te vergewissen dat je aan alles hebt gedacht, maar in de praktijk komt er uiteraard bij alle aspecten van deze kubus aardig wat kijken.

de cyberboswachters van de 21e eeuw hebben geen eenvoudige job. Ze was in de vorige eeuw al pittig, de laatste is de wapenwedloop er helaas alleen maar grimmiger op geworden.

- De aanvallers kunnen aan bijna supersonische **snelheid** aanvallen op duizenden, of zelfs miljoenen, systemen starten.
- De gemiddelde aanval is duizenden keren **complexer** dan de aanvallen die we circa 20 jaar geleden te verduren kregen.
- De tools die aanvallers, van welke aard ook, ter hun beschikking hebben is vaak ongelooflijk **eenvoudig** geworden. Gedaan is de tijd dat een ietwat stevige aanval kon gedaan worden door experts met 10 jaar scrip- en netwerkervaring. Sommige vreeswekkende aanvallen vereisen niet meer dan het IP-adres van het slachtoffer in een invulveld invullen en vervolgens een klik op een grote rode knop “Start attack”.
- Aanvallers schuimen *underground* fora af, op zoek naar de nieuwste *zero-day* die ze in hun arsenaal kunnen opnemen. Fabrikanten van besturingssystemen en software kunnen de **snelheid waarmee nieuwe zwakheden** in hun systeem worden gevonden niet volgen.
- Door voorgaande snelheid van nieuwe zwakheden, duurt het ook langer en langer voor alles kan **gepatched** worden door de ontwikkelaars van de software.
- Aanvallers kunnen **gigantische legers van computers en botnets** gebruiken om een ijzingwekkende hoeveelheid aan simultane aanvallen op één enkel slachtoffer uit te voeren.
- **Gebruikers** zijn een nog kleiner radertje in dit alles geworden en zullen nog sneller fouten maken (klikken op een link in een phishing email bijvoorbeeld) dan voorheen, met alle gevolgen van dien.

Zero days en patching

Aanvallers hebben voor zero days aardig wat geld over. Een zero day kopen is een aanval kopen die gegarandeerd zal werken daar deze een zwakte misbruikt die nog niet bij de maker van de software gekend is.

Een zero day zal quasi gegarandeerd blijven werken tot de ontwikkelaars een nieuwe patch ervoor maken. Maar zelfs dan blijven zero days nuttig: het is niet omdat er een patch bestaat, dat de slachtoffers deze patch ook effectief reeds geïnstalleerd hebben. Veel bedrijven hebben nu erg strenge *patching policies* maar toch blijft het dweilen met de kraan open: er moet maar 1 systeem niet gepatche'd zijn

tegen de zero day van de aanvallers en het gaatje in de verdedigingslinie is gevonden en kan misbruikt worden.

De meeste fabrikanten van besturingssystemen (Apple, Microsoft, etc.) en veelgebruikte softwarepakketten (Adobe, Microsoft, etc.)



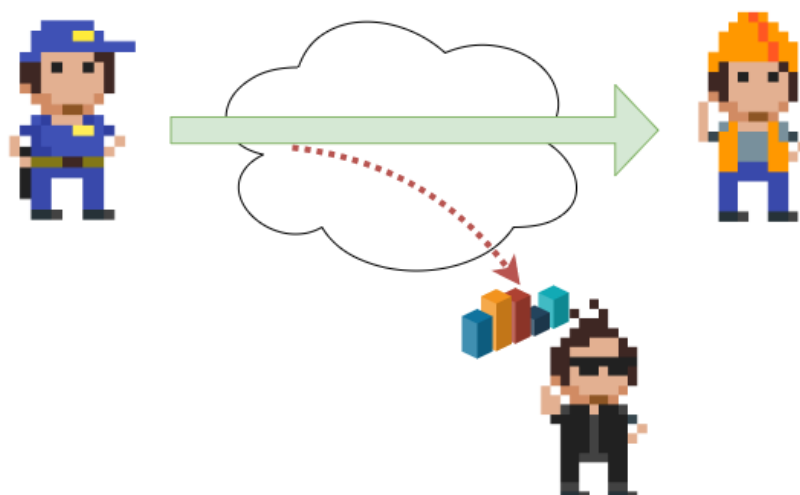
Hier ontbreekt nog vanalles, maar ik was het typen even beu en wilde al wat tekeningetjes maken voor een sectie verderop:)

Classificatie van aanvallen

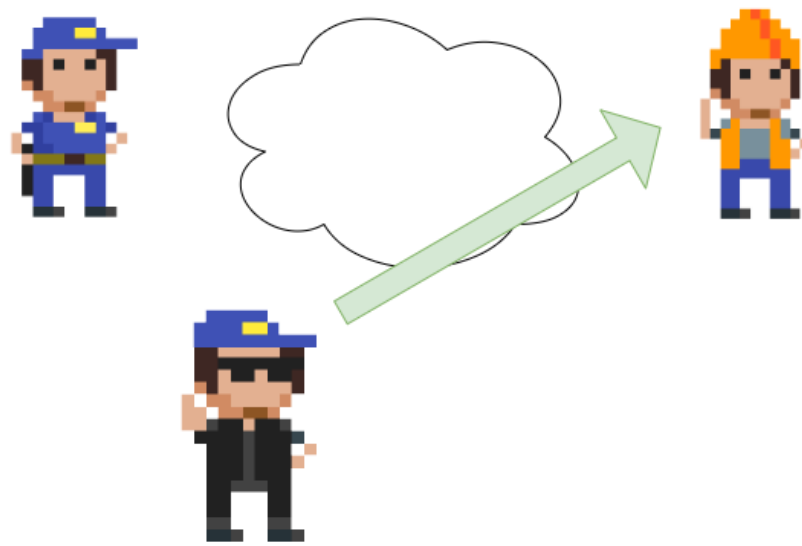


Figuur 0.2: Passief vs actief

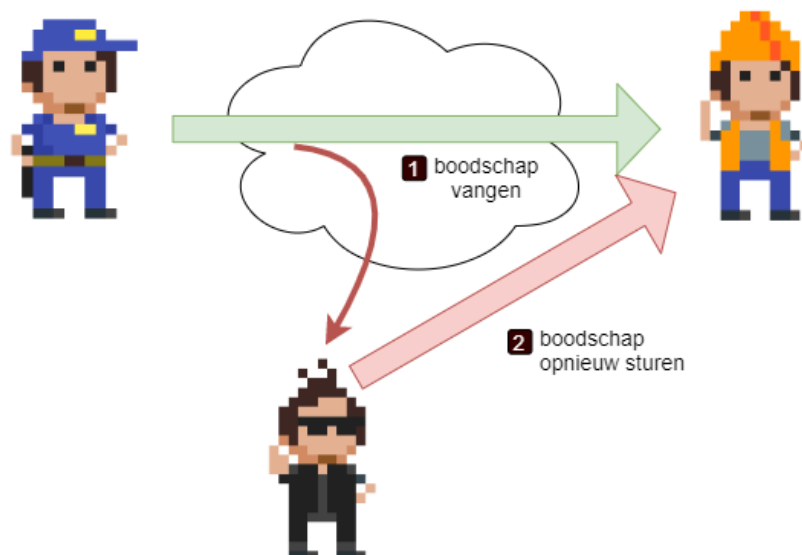
Passieve aanval, type 1: sniffing



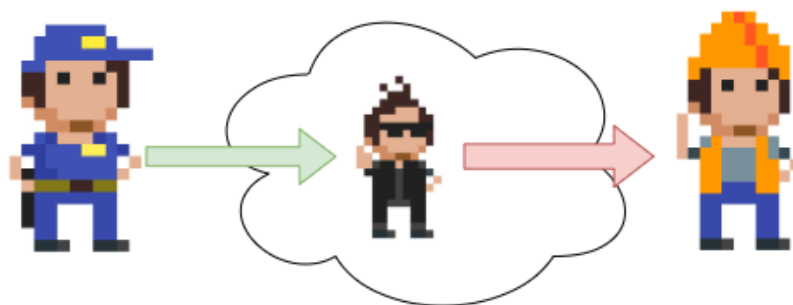
Figuur 0.3: Passieve aanval, type 2: trafief analyse



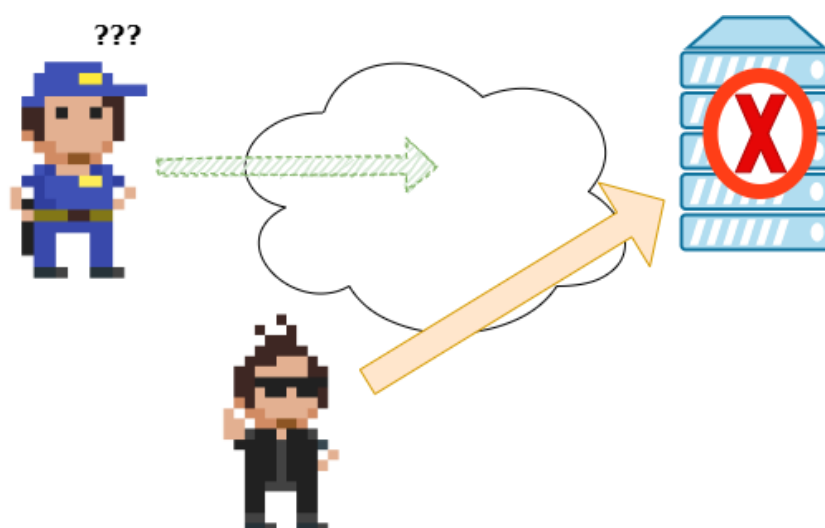
Figuur 0.4: Masquerading



Figuur 0.5: Replay attack



Figuur 0.6: Man-in-the-middle attack



Figuur 0.7: denial-of-service aanval

Dankwoord

Een oprechte dank aan Stefaan Somerling (RealDolmen) voor de feedback op het hoofdstuk omtrent GDPR. Geef gerust een sein als u, conform de GDPR wetgeving, liever uw naam niet in dit document ziet staan ;)

Dank aan eerstejaars Dimitriy Vassilchenko om als externe spellingchecker aardig wat (genante) typos te ontdekken!

Bronnen

- 802.11 Wireless Network (first edition), Gast, O'Reilly, ISBN: 0-596-0018-3
- Meerdere boeken van William Stallings (Computer Security, Cybersecurity, etc.)

